Data Flow Diagram และความเป็นส่วนตัว: RAG-Diary

> แสดงการไหลของข้อมูลในระดับบริบทและระดับกระบวนการ โดยเน้นเส้นทางของข้อมูลส่วนบุคคล จุดที่ข้อมูลข้ามขอบเขตความเชื่อถือไปยังบุคคลที่สาม และมาตรการคุ้มครองที่ใช้อยู่

1. Document Control

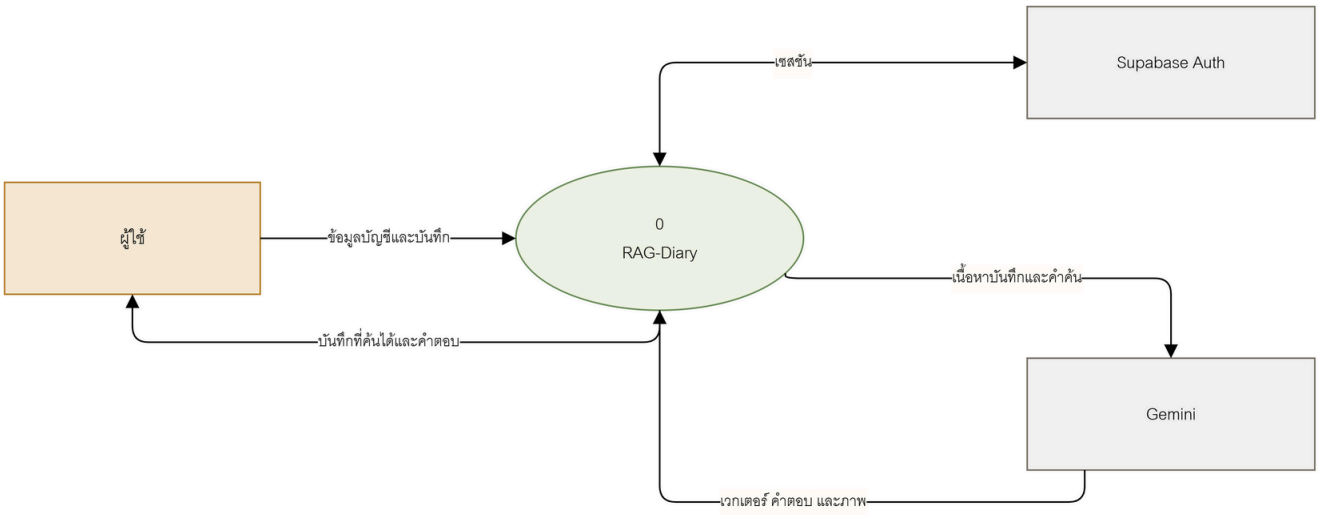
หัวข้อ	รายละเอียด
ชื่อเอกสาร	Data Flow Diagram และความเป็นส่วนตัว
เวอร์ชัน	1.0
วันที่จัดทำ	15 ตุลาคม 2569
ผู้จัดทำ	Business Analyst / System Analyst (เจ้าของผลงาน)
สถานะ	ผ่านการตรวจทานรอบ 1 (25 ตุลาคม 2569)
เอกสารที่เกี่ยวข้อง	C4-ARCHITECTURE, DATA-MODEL, BUSINESS-RULES, NFR-SPEC

2. Purpose และ Scope

เอกสารนี้ตอบคำถามว่า "ข้อมูลของผู้ใช้ไหลผ่านส่วนไหนบ้าง และตรงไหนที่ข้อมูลอ่อนไหวออกไปนอกขอบเขตที่เราควบคุม" เพื่อใช้ทบทวนด้านความเป็นส่วนตัวก่อนเปิดใช้งาน

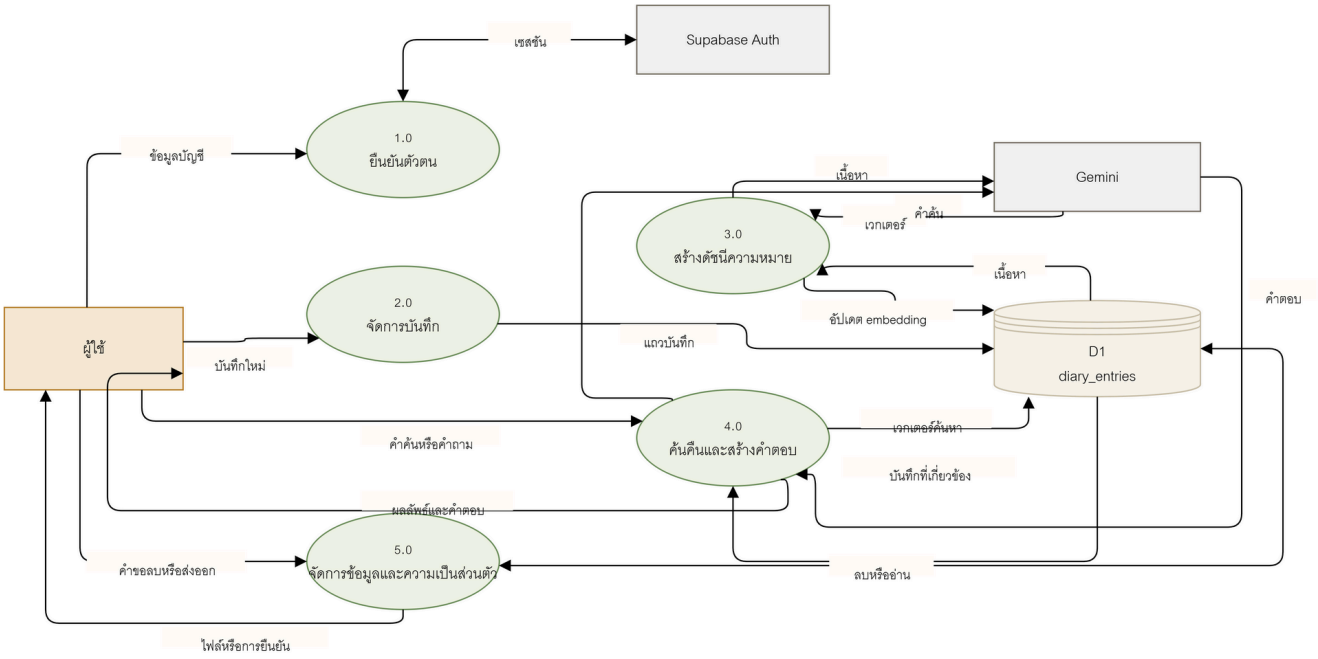
ขอบเขต: แผนภาพการไหลของข้อมูลสองระดับ เส้นแบ่งขอบเขตความเชื่อถือ รายการข้อมูลส่วนบุคคล และมาตรการคุ้มครอง นอกขอบเขต: รายละเอียดโครงสร้างข้อมูล (อยู่ใน DATA-MODEL) และตัวชี้วัดด้านความปลอดภัย (อยู่ใน NFR-SPEC)

3. DFD Level 0 (Context Diagram)



ข้อมูลส่วนบุคคลในรูปเนื้อหาบันทึกและคำค้นข้ามขอบเขตออกไปยัง Google Gemini ทุกครั้งที่มีการสร้างดัชนีหรือสร้างคำตอบ จุดนี้เป็นจุดที่ต้องมีการแจ้งและขอความยินยอมตาม NFR-03

4. DFD Level 1



องค์ประกอบ	ประเภท	คำอธิบาย
1.0 ยืนยันตัวตน	กระบวนการ	จัดการลงทะเบียน เข้าสู่ระบบ และเซสชัน
2.0 จัดการบันทึก	กระบวนการ	สร้าง อ่าน แก้ไข และลบบันทึก
3.0 สร้างดัชนีความหมาย	กระบวนการ	แปลงเนื้อหาเป็นเวกเตอร์และอัปเดตดัชนี
4.0 ค้นคืนและสร้างคำตอบ	กระบวนการ	ค้นด้วยความหมายและสร้างคำตอบจากบริบท
5.0 จัดการข้อมูลและความเป็นส่วนตัว	กระบวนการ	ส่งออกและลบข้อมูลของผู้ใช้
D1 diary_entries	ที่เก็บบันทึกข้อมูล	เก็บบันทึกและเวกเตอร์ พร้อม RLS
E2 Supabase Auth	เอนทิตีภายนอก	ผู้ให้บริการยืนยันตัวตน
E3 Google Gemini	เอนทิตีภายนอก	ผู้ให้บริการสร้างเวกเตอร์และคำตอบ

5. รายการข้อมูลส่วนบุคคล (PII Inventory)

ข้อมูล	ที่เก็บ	ไหลออกไปที่ใด	วัตถุประสงค์	มาตรการคุ้มครอง
อีเมล	Supabase Auth	ไม่ไหลออกนอกผู้ให้บริการยืนยันตัวตน	ยืนยันตัวตนและระบุบัญชี	จัดการโดยผู้ให้บริการยืนยันตัวตน
รหัสผ่าน	Supabase Auth	ไม่ไหลออก	ยืนยันตัวตน	เก็บแบบเข้ารหัสทางเดียวที่ผู้ให้บริการ
เนื้อหาบันทึก	diary_entries	Google Gemini เฉพาะเมื่อสร้างดัชนีหรือสร้างคำตอบ	สร้างเวกเตอร์และคำตอบ	RLS, ขอความยินยอม, ลบและส่งออกได้

ข้อมูล	ที่เก็บ	ไหลออกไปที่ใด	วัตถุประสงค์	มาตรการคุ้มครอง
เวกเตอร์ (embedding)	diary_entries	ไม่ไหลออก	ค้นคืนเชิงความหมาย	RLS
แท็ก	diary_entries	รวมไปกับเนื้อหาที่ส่งให้ Google Gemini	จัดหมวดบันทึก	RLS
เวลาที่สร้าง	diary_entries	ไม่ไหลออก	เรียงลำดับบันทึก	RLS
เซสชัน (cookie httpOnly)	เบราว์เซอร์ของผู้ใช้	ไม่ไหลออกนอกระบบ	คงสถานะการเข้าสู่ระบบ	JavaScript อ่านไม่ได้ ตั้ง Secure และ SameSite=Lax

6. จุดข้ามขอบเขตความเชื่อถือ

จุด	ข้อมูลที่ข้าม	ผู้รับ	มาตรการ	ความต้องการที่เกี่ยวข้อง
สร้างดัชนีความหมาย	เนื้อหาบันทึก	Google Gemini	แจ้งและขอความยินยอมก่อนใช้งาน	NFR-03, BR-06
ค้นคืนและสร้างคำตอบ	คำค้นหรือคำถาม และเนื้อหาบันทึกบางส่วน	Google Gemini	ใช้ดัชนีของผู้ใช้ที่ล็อกอินเท่านั้น	FR-10, BR-05
สร้างภาพ	prompt ที่ได้จากบันทึก	Google Gemini	มาจากการกระทำของผู้ใช้โดยตรง	FR-12
จัดเก็บข้อมูล	ข้อมูลทั้งหมด	Supabase	เป็นผู้ประมวลผลข้อมูลตามสัญญาบริการ	NFR-02

7. มาตรการคุ้มครองความเป็นส่วนตัวที่เป็นอยู่

- การแยกข้อมูลบังคับด้วย RLS ที่ฐานข้อมูล ผู้ใช้หนึ่งเข้าถึงข้อมูลของอีกคนไม่ได้ (FR-15, BR-01)
- ผู้ใช้ส่งออกข้อมูลของตนเองได้ (FR-13) และลบข้อมูลทั้งหมดได้ (FR-14)
- คำตอบจาก AI อ้างอิงเฉพาะบันทึกของผู้ใช้ที่ถาม (BR-05)
- การแจ้งและขอความยินยอมก่อนส่งข้อมูลไปประมวลผลภายนอก (NFR-03, BR-06)

8. ข้อสังเกตและข้อเสนอ

ประเด็น	สถานะ	ข้อเสนอ
การขอความยินยอม	บังคับใช้แล้วฝั่งไคลเอนต์: แจ้งและขอความยินยอมก่อนใช้ฟีเจอร์ AI ทุกครั้ง และเพิกถอนได้ในหน้าตั้งค่า	เก็บหลักฐานความยินยอมระดับบัญชี และตรวจถ้อยคำกับผู้กำกับดูแลข้อมูลก่อนเผยแพร่
การเก็บ token	อยู่ใน cookie แบบ httpOnly ที่ JavaScript อ่านไม่ได้	ต้องตั้ง Secure และ SameSite ให้ถูกทุกสภาพแวดล้อม
การส่งข้อมูลไปต่างประเทศ	เนื้อหาส่งไปยังผู้ให้บริการภายนอก	ระบุฐานทางกฎหมายและแจ้งผู้ใช้ให้ชัด
การบันทึก log	ยังไม่มีนโยบายลบ log ที่มีข้อมูลอ่อนไหว	กำหนดระยะเวลาเก็บและปิดข้อมูลในการบันทึก log

9. References

เอกสาร	ความสัมพันธ์
C4-ARCHITECTURE	ส่วนประกอบที่ปรากฏใน DFD
DATA-MODEL	ที่เก็บข้อมูลและนโยบาย RLS

เอกสาร	ความสัมพันธ์
BUSINESS-RULES	กฎที่กำหนดการไหลของข้อมูล
NFR-SPEC	ตัวชี้วัดด้านความปลอดภัยและความเป็นส่วนตัว